

The Human Side of the Hook

*A Field Guide to Research on Phishing, Social Engineering,
and Digital Trust*

Karina Sætersdal Nilssen

Oslo Metropolitan University

Department of Computer Science

ACIT4100 · Essay · Autumn 2026

Referansestil: APA 7th edition (Kildekompasset). Dobbelt linjeavstand (2.0). Hengende innrykk i referanseliste (0,5 tommer / 1,27 cm).
Henvisninger: forfatter-år i parentes. Organisasjonsforkortelser definert ved første bruk (f.eks. NSM, ENISA).

Abstract

This essay describes the research field of human factors in cybersecurity, with emphasis on phishing, social engineering, and digital trust. Rather than evaluating a technology product or presenting original experiments, it summarises how researchers ask questions, which methods they use (experiments, surveys, vignettes, mixed methods), and how the field relates to ethics, regulation, publication traditions, and society. Classic prose carries the main argument; three narrative cut-scenes illustrate how research connects to everyday digital decisions. The field is presented as an evolving interdisciplinary domain shaped by debates on user blame, lure-specific vulnerability, and the limits of awareness training.

Keywords: human factors, phishing, social engineering, research methods, APA, cybersecurity behaviour

Introduction

Every year, organisations spend heavily on firewalls, filters, and multi-factor authentication. Every year, phishing remains one of the most common ways attackers enter systems. The gap between technical investment and human compromise is not a mystery to one research community: scholars who study human factors in cybersecurity. Their job is not primarily to build better malware signatures. It is to understand why cautious, literate people still click.

This essay describes that field of research as it exists today: how it asks questions, how it produces knowledge, where it publishes, how it relates to law and ethics, and why it matters to society beyond the security operations centre. The focus is the research itself, not a technology product review. Where the course invites narrative style, short cut-scenes appear between sections; they illustrate how research questions emerge from ordinary digital life, not to invent new findings but to ground the reader in the world this science tries to explain.

The field sits at the intersection of cybersecurity, psychology, human-computer interaction, and organisational behaviour. It is heterogeneous by design. Some studies run controlled experiments in university labs; others analyse real incident reports; still others conduct interviews with fraud victims or security awareness trainers. What unites them is a shared rejection of the idea that phishing persists because users are uniformly naive. The research field treats phishing as a problem of meaning, context, and decision under pressure.

Cut-scene (narrative style)

She refreshes her inbox between lectures. A message from "OsloMet IT" asks her to reset her password within the hour. She has heard the warnings about unknown senders. She has also received real IT notices before. She hovers over the link. In another building, a researcher reads survey responses describing exactly this moment—not to judge the student, but to learn what "credible" looks like when fear and habit collide.

What this research field studies

Human factors cybersecurity research examines how people perceive, evaluate, and respond to security threats in everyday digital environments. Phishing and social engineering are central because they exploit communication channels users already trust: email, SMS, messaging apps, and voice calls (Conteh & Schmick, 2020; Hadnagy, 2018).

Typical research objects include susceptibility to deceptive messages, effectiveness of awareness training, reporting behaviour after near misses, cognitive and emotional predictors of unsafe actions, and organisational culture around blame and disclosure (Chen et al., 2024; Parker & Flowerday, 2020). Norwegian studies by Tjostheim and Waterworth (2020, 2022) exemplify national contributions linking cognitive reflection to phishing compliance in representative samples.

The field does not treat "the user" as a homogeneous category. Recent work emphasises lure-specific vulnerability: people may reject stranger scams yet hesitate on messages impersonating institutions, peers, or employers (Klüttsch et al., 2024). That line of inquiry connects to broader debates about digital trust in high-trust societies such as Norway, where BankID, Altinn, and university IT communication create both convenience and impersonation risk

(Finans Norge, 2026; Norwegian National Security Authority [NSM], 2026).

Notable researchers, groups, and centres

Human factors security research is distributed globally rather than centred in one laboratory. Influential researchers include Christopher Hadnagy on social engineering practice and ethics (Hadnagy, 2018); Steven Pinker on classic prose style used in science communication (Pinker, 2014); and scholars such as Parker and Flowerday (2020) and Tsai (2021) on phishing persuasion and organisational context.

Institutional clusters include Carnegie Mellon's CyLab and usable security traditions; the Symposium on Usable Privacy and Security (SOUPS) community; European Union Agency for Cybersecurity (ENISA) research networks; and Nordic contributions through Norwegian ICT conferences where Tjostheim and Waterworth publish representative-sample phishing studies (Tjostheim & Waterworth, 2020, 2022).

Industry research units publish threat data that academia cites for motivation but rarely for method. Students mapping the field should distinguish corporate report series from peer-reviewed archives (European Union Agency for Cybersecurity [ENISA], 2024; Halcyon, 2026).

How to read and approach scientific work in this field

Course guidance emphasises skill in locating and reading scientific sources rather than producing anthropology from scratch. A practical workflow: define the field boundary (human factors and phishing); search ACM Digital Library and IEEE with terms such as "phishing susceptibility," "social engineering," and "usable security"; skim

abstracts for method type; read methods and limitations before discussion sections.

When synthesising, note sample population (students, employees, nation), lure type (email, SMS, social), and outcome (click, report, self-report intention). Compare whether authors claim user deficit or systemic/contextual explanation—that ideological split runs through the literature and helps organise an essay thematically.

Students are not required to judge statistical quality at expert level, but reporting how authors interpret their own findings is expected. Phrases such as "the authors argue" or "the study suggests, within undergraduate samples" keep interpretation honest, as recommended in academic writing guidance (Pinker, 2014).

Regulatory and professional constraints in Norway

Norwegian researchers must align with the Norwegian Agency for Shared Services in Education and Research (SIKT) notification or approval requirements for personal data on behaviour and sensitive topics such as loneliness and fraud victimisation. National campaigns by Finans Norge (2026) and NSM (2026) shape public scepticism but are not research instruments—students should not confuse policy documents with empirical studies.

Working life and education law intersect when organisational phishing simulations affect employees or students. Punitive simulation designs have been criticised in research literature for suppressing reporting (Chen et al., 2024; Bayl-Smith et al., 2024)—the regulatory environment for such programmes is organisational policy as much as national law.

Effects of this research upon society

When effective, human factors research changes training content, incident response playbooks, and public messaging. When ignored, organisations continue blaming users while impersonation of BankID, Altinn, and university IT persists (Norwegian National Security Authority [NSM], 2026; Norwegian Police, 2024).

Social effects include reduced shame when non-punitive reporting is normalised (Chen et al., 2024); potential stigmatisation if loneliness is framed as individual risk rather than structural student-life issue; and improved digital literacy when lure-specific examples replace generic "don't click" slogans (Finans Norge, 2026).

The research field does not operate in a vacuum: student wellbeing surveys (SHoT Study, 2022) and cybersecurity awareness modules rarely cross-reference each other, yet both speak to student vulnerability in digital environments (Directorate of Health, 2024; Statistics Norway, 2025). Describing that silo is part of describing the field's societal embedding.

Style note: classic and narrative hybrid

This essay applies classic style in the main exposition: direct statements, active verbs, concrete nouns, and sequential reasoning as Pinker (2014) recommends for clarifying complex ideas to a general educated reader. Narrative cut-scenes function like documentary B-roll: they do not introduce new empirical claims but situate the reader emotionally before returning to synthesis of published research.

A purely narrative essay could embed all perspectives inside fiction; a purely classic essay could omit cut-scenes entirely. The

hybrid used here mirrors televised documentary structure permitted by
the 2026 assignment brief.

Research methods and methodologies

Methodological pluralism defines this field. No single method owns the truth about human clicking behaviour. Instead, researchers combine approaches depending on whether they need experimental control, ecological validity, or lived experience.

Experimental and laboratory designs

Controlled experiments remain common. Participants receive simulated phishing emails or messages in lab or online settings; researchers manipulate variables such as sender identity, urgency, authority cues, or grammatical quality (Tsai, 2021). Dependent variables include click rates, credential entry, time to decision, and self-reported suspicion.

Strengths include isolation of causal factors, reproducibility, and statistical power. Weaknesses include simulated attacks that may not carry real consequences and participant awareness of being studied, which can inflate cautious behaviour (social desirability bias). Ethics boards therefore scrutinise deceptive designs carefully (Chen et al., 2024).

Surveys and scenario vignettes

Large-scale surveys measure self-reported behaviour, attitudes, loneliness, scepticism, and intended responses to hypothetical scenarios (vignettes). Vignettes manipulate lure framing—stranger, institutional, social, authority—without exposing participants to live malware (Parker & Flowerday, 2020).

This approach scales nationally, as Tjostheim and Waterworth (2020, 2022) demonstrated in Norway. Trade-off: intended behaviour may differ from behaviour under real loss or embarrassment.

Mixed methods and qualitative inquiry

Mixed-methods designs increasingly combine surveys with semi-structured interviews or thematic analysis (Braun & Clarke, 2006). Quantitative strands identify patterns; qualitative strands explain mechanisms—shame, credibility cues, reporting culture—that numbers alone cannot capture (Chen et al., 2024).

Integration techniques include joint displays linking statistical results with anonymised quotes (Fetters et al., 2013). This reflects a maturing field that treats human factors as more than a regression table.

Field studies and industry collaboration

Some research analyses organisational phishing simulations, help-desk tickets, or anonymised incident data with industry partners. Access is negotiated under confidentiality agreements. Findings inform training design but may not be fully public.

Threat intelligence reports from ENISA (2024), Microsoft (2024), and NSM (2026) provide macro context but rarely substitute for peer-reviewed human-subjects research.

Cut-scene (narrative style)

The lab room is quiet except for keyboard clicks. On screen, red and green bars compare click rates across two email templates. The researcher notes that version B added only one line: "Your supervisor requested this today." No new exploit code. Just words. The experiment will become a conference slide; later,

perhaps, a training module—if the reviewers agree the effect is real.

Philosophy of science in the field

Human factors cybersecurity research draws on multiple philosophical traditions, often implicitly rather than through explicit manifestos.

Positivist and post-positivist strands dominate experimental and survey work: hypotheses, measurable variables, falsification, effect sizes. Protection Motivation Theory from health psychology migrated into security behaviour research under this logic (Floyd et al., 2000; Rogers, 1975; Bayl-Smith et al., 2024).

Interpretivist and constructivist strands appear in interview-based and ethnographic work: meaning is situated; "risk" is co-produced by users, institutions, and attackers. A message is not objectively phishing until interpreted in context (Braun & Clarke, 2006).

Critical perspectives question the "weakest link" metaphor that locates failure inside individuals while obscuring organisational responsibility (Hadnagy, 2018). Some scholars frame phishing as a socio-technical failure: systems generate high volumes of ambiguous communication; attackers exploit trust infrastructures citizens rely on daily.

The field rarely resolves these philosophies into one camp. Pragmatism wins: mixed methods prevail because the phenomenon is too messy for a single epistemology (Fetters et al., 2013).

History and development of the field

Phishing as a research object dates to the early 2000s when mass email fraud became visible to academia and industry simultaneously. Early work catalogued technical indicators—spoofed headers, URL obfuscation—and user ignorance.

The shift toward human factors accelerated as defences improved and attackers pivoted to social manipulation. Hadnagy's (2018) social engineering literature and annual industry reports documented that technical maturity did not eliminate human entry points.

Human-computer interaction venues such as CHI and SOUPS began accepting phishing behaviour papers alongside usable security workshops. Psychology and consumer fraud research on loneliness and persuasion cross-pollinated with cybersecurity during the 2010s (Alves & Wilson, 2008; Cacioppo & Patrick, 2008).

Norwegian contributions emerged through national ICT conferences and representative surveys (Tjostheim & Waterworth, 2020, 2022), aligning local digitalisation (BankID culture) with empirical behaviour research.

Recent trajectories include AI-assisted lure generation (Halcyon, 2026; Trend Micro, 2026), loneliness and student wellbeing links (SHoT Study, 2022; Statistics Norway, 2025), and scepticism paradox framing—why general caution toward strangers coexists with institutional impersonation vulnerability (Klüttsch et al., 2024).

Publication traditions: journals and conferences

Researchers in this field publish across security, HCI, and organisational journals. Notable outlets include *Computers & Security*, *Computers in Human Behavior*, *Information and Computer Security*, *Journal of Cybersecurity*, and proceedings from CHI, SOUPS, and USENIX Security workshops (Parker & Flowerday, 2020; Tsai, 2021).

Interdisciplinary acceptance varies. A vignette study may face reviewer questions from both psychologists ("Is the scale validated?") and security engineers ("Where is the threat model?"). Successful papers often include explicit threat context and reproducible instruments.

Grey literature—NSM risk assessments, ENISA threat landscapes, Finans Norge fraud campaigns—shapes public discourse and student motivation but does not replace peer review for academic essays. Students learning the field must read both: reports for timeliness, journals for methodology transparency (ENISA, 2024; NSM, 2026).

Ethics, regulation, and codes of conduct

Ethics is not peripheral in this field; it is structural. Deceptive experiments (simulated phishing without consent) can harm participants through shame, misplaced blame, or unintended disclosure of personal habits (Chen et al., 2024).

Institutional review boards and national agencies such as SIKT in Norway evaluate whether deception is justified, whether debriefing is adequate, and whether data minimisation is observed. Live phishing against unwitting participants is generally rejected; vignettes and announced simulations are preferred.

The General Data Protection Regulation governs storage of behavioural data. Fraud victimisation questions require content warnings. Reporting near misses in organisational studies must protect employee identity (Alves & Wilson, 2008).

Professional codes in cybersecurity emphasise lawful behaviour and public good, but academic research adds informed consent and right to withdraw. Tension arises when industry partners want identifiable incident data researchers cannot ethically provide (Hadnagy, 2018).

Cut-scene (narrative style)

The ethics form asks: "Will participants be deceived?" She checks "minimal deception—scenario vignettes only." The committee asks for a debrief link to svindel.no (Finans Norge, 2026). Outside, autumn rain on the campus windows. Research here moves slowly—not because computers are slow, but because people matter.

Relationship with society, industry, and other experts

Human factors research connects to multiple publics. Industry consumes findings for awareness programmes, simulated phishing metrics, and security culture initiatives. Governments reference human behaviour in national risk assessments (NSM, 2026). Banks and finance associations run public literacy campaigns (Finans Norge, 2026).

Student welfare services encounter loneliness and digital fraud as parallel student-life issues; research that bridges them must communicate carefully to avoid stigmatising vulnerable groups (Directorate of Health, 2024; SHoT Study, 2022).

Relations with "hard" security research are complementary. Cryptographers and malware analysts ask what is technically possible; human factors researchers ask what is psychologically plausible. Incident responders supply anecdotes; academics supply sampling frames and statistics (ENISA, 2024).

Disagreement exists. Some practitioners dismiss academic effect sizes as irrelevant to security operations centre workload; some academics criticise punitive phishing simulations in workplaces (Bayl-Smith et al., 2024; Chen et al., 2024). The research field documents both sides rather than enforcing unity.

How researchers produce and synthesise knowledge

Students in ACIT4100 are not expected to invent new models. The task mirrors what working researchers do in literature reviews: search databases (ACM, IEEE, Scopus, Google Scholar); trace citation

chains; compare methods; note geographic and sample biases; synthesise trends.

Quality signals include pre-registration for experiments, open instruments, representative sampling, preregistered analysis plans, and replication attempts. Weak signals include convenience samples without boundary discussion, click-rate-only metrics without context, and fear-based training evaluations without coping measures (Bayl-Smith et al., 2024).

Meta-analyses on protection motivation and security behaviour aggregate decades of small studies (Floyd et al., 2000). Narrative reviews in ENISA and industry reports aggregate incident trends without human-subjects detail. A well-written field essay cites both types while respecting their limits.

Current debates within the field

Active debates include whether simulated phishing in workplaces improves behaviour or increases shame (Chen et al., 2024); whether AI-generated lures change psychology or only aesthetics (Halcyon, 2026; Trend Micro, 2026); whether loneliness predicts fraud susceptibility equally across age groups (Klüttsch et al., 2024; Wen et al., 2024); and whether general scepticism training transfers to institutional impersonation.

These debates are not settled. The essay reports them as the living edge of the field—the places where new master's theses and industry pilots attach.

Conclusion: communicating research as technologists

Human factors cybersecurity research is a field where technologists learn to read humans with the same rigour they read code—through methods, ethics, history, and public consequence. It explains why phishing survives technical progress: attackers optimise for trust, urgency, and belonging, not only for software bugs (Hadnagy, 2018; Tsai et al., 2021).

For ACIT students, understanding this field means knowing where knowledge comes from, not only what the latest awareness poster says. It means recognising journals, ethics constraints, and societal stakeholders. It means writing about research in clear classic prose, occasionally illuminated by narrative cut-scenes that remind us that behind every dataset is someone hovering over a link between lectures (Pinker, 2014).

The field will keep evolving as digital trust infrastructures evolve. Norway's combination of high institutional trust and measurable social disconnection among young adults makes it a relevant site for contemporary work—not because Norwegians are uniquely weak, but because the research questions about scepticism, loneliness, and credible impersonation are unusually visible here (NSM, 2026; Statistics Norway, 2025).

To enter this field as a reader or future contributor is to accept a split attention: technical systems and human meaning. The research community studies that split for a living. This essay has mapped how they do it.

References

- Alves, L. M., & Wilson, S. R. (2008). The effects of loneliness on telemarketing fraud vulnerability among older adults. *Journal of Elder Abuse & Neglect*, 20(1), 63–85. <https://doi.org/10.1080/08946560801973137>
- Bayl-Smith, P., Taib, R., Yu, K., & Wiggins, M. W. (2024). Response to a phishing attack: Persuasion and protection motivation in an organizational context. *Information and Computer Security*.
- Braun, V., & Clarke, V. (2006). Using thematic analysis in psychology. *Qualitative Research in Psychology*, 3(2), 77–101. <https://doi.org/10.1191/1478088706qp063oa>
- Cacioppo, J. T., & Patrick, W. (2008). *Loneliness: Human nature and the need for social connection*. W. W. Norton & Company.
- Chen, Y. (2024). *The effects of group discussion and role-playing training on self-efficacy, support-seeking, and reporting phishing emails* [Conference presentation]. CHI Conference on Human Factors in Computing Systems. <https://doi.org/10.1145/3613904>
- Conteh, N. Y., & Schmick, P. J. (2020). Cybersecurity risks, vulnerabilities, and countermeasures to prevent social engineering attacks. In *Cyber security and threats: Concepts, methodologies, tools, and applications* (pp. 1–27). IGI Global. <https://doi.org/10.4018/978-1-7998-6504-9.ch002>
- Directorate of Health. (2024). *Social isolation and loneliness: Strategy for prevention and reduction*. <https://www.helsedirektoratet.no>

- European Union Agency for Cybersecurity. (2024). *ENISA threat landscape 2024*. <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2024>
- Fetters, M. D., Curry, L. A., & Creswell, J. W. (2013). Achieving integration in mixed methods designs—principles and practices. *Health Services Research*, 48(6), 2134–2156. <https://doi.org/10.1111/1475-6773.12117>
- Finans Norge. (2026). *Selvforvar mot svindel*. <https://www.svindel.no>
- Floyd, D. L., Prentice-Dunn, S., & Rogers, R. W. (2000). A meta-analysis of research on protection motivation theory. *Journal of Applied Social Psychology*, 30(2), 407–429. <https://doi.org/10.1111/j.1559-1816.2000.tb02323.x>
- Hadnagy, C. (2018). *Social engineering: The science of human hacking* (2nd ed.). Wiley.
- Halcyon. (2026). *AI and ransomware threat report*. <https://www.halcyon.ai>
- Klütsch, J., Schwab, J., Boffel, C., Zimmermann, V., & Schlittmeier, S. J. (2024). Friend or phisher? How known senders and fear of missing out affect young adults' phishing susceptibility on social media. *Humanities and Social Sciences Communications*, 11(1), Article 145. <https://doi.org/10.1057/s41599-024-03412-8>
- Kildekompasset. (n.d.). *APA 7th edition*. <https://kildekompasset.no/referansestiler/apa-7>
- Microsoft. (2024). *Digital defense report 2024*. <https://www.microsoft.com/en-us/security/security-insider/microsoft-digital-defense-report>

- Norwegian National Security Authority. (2026). *National cyber security risk assessment 2026*. <https://www.nsm.no>
- Norwegian Police. (2024). *Report online fraud*. <https://www.politiet.no/rad/nettsvindel>
- Parker, H. J., & Flowerday, S. V. (2020). Contributing factors to increased susceptibility to social media phishing attacks. *South African Journal of Information Management*, 22(1), a1176. <https://doi.org/10.4102/sajim.v22i1.1176>
- Pinker, S. (2014). *The sense of style: The thinking person's guide to writing in the 21st century*. Viking.
- Rogers, R. W. (1975). A protection motivation theory of fear appeals and attitude change. *Journal of Psychology*, 91(1), 93–114. <https://doi.org/10.1080/00223980.1975.9915803>
- SHoT Study. (2022). *Student health and wellbeing survey (SHoT2022)*. <https://shot.no>
- Statistics Norway. (2025). *How many people feel lonely in Norway? Quality of life survey*. <https://www.ssb.no/sosiale-forhold-og-kriminalitet/levekare/statistikk/livskvalitet>
- Tjostheim, I., & Waterworth, J. A. (2020). Phishing susceptibility in a Norwegian sample. In *Proceedings of Norsk IKT-konferanse for forskning og utdanning*.
- Tjostheim, I., & Waterworth, J. A. (2022). Cognitive reflection and phishing susceptibility. In *Proceedings of Norsk IKT-konferanse for forskning og utdanning*.
- Trend Micro. (2026). *Phishing threat report 2026*. <https://www.trendmicro.com>

Tsai, H.-Y. (2021). Phishing and persuasion strategies [Article manuscript]. *Computers & Security*.

Wen, J., Yang, H., Zhang, Q., & Shao, J. (2024). Loneliness could lead to risk of fraud victimization for middle-aged and older adults. *Journal of Elder Abuse & Neglect*. <https://doi.org/10.1080/08946566.2024.2404040>

Referanselisten er formatert etter APA 7th edition (Kildekompasset). Kontroller alle DOI-er, forfatterlister og URL-er i Zotero/Ordbok før endelig innlevering.